APIs de rede na prática

CAMARA e GSMA Open Gateway: 5 experimentos no sandbox



O que vamos ver

Fundamentos

1. O tema: o que a rede móvel sabe
2. API CAMARA: o padrão aberto
3. O sandbox e o nosso método

Em cada módulo

- O que a funcionalidade faz
- O cenário de aplicação
- As chamadas e a POC
- Vantagens e cuidados

Os 5 módulos

01 **Verificação de localização**
cenário: antifraude de cartão

02 **Know Your Customer**
cenário: abertura de conta

03 **Código por SMS (OTP)**
cenário: login e Pix

04 **Localização do aparelho**
cenário: socorro na estrada

05 **Troca de chip (SIM Swap)**
cenário: golpe da troca de chip

A rede móvel sabe coisas que nenhum app sabe



Quem é o dono da linha

O chip é cadastrado com nome e CPF do titular.



Onde o aparelho está

A antena que atende o chip indica a região.



Se a linha é nova

Desde quando a linha existe e quando o chip foi trocado.



Como falar com o celular

A operadora entrega mensagens direto ao aparelho.

As APIs de rede deixam um app fazer perguntas à operadora sobre essas informações, sem receber os dados pessoais do cliente.

Por que isso importa: fraudes do dia a dia

O PROBLEMA	A PERGUNTA À OPERADORA	
Cartão clonado usado numa loja	O celular do cliente está perto da loja?	Módulo 01
Conta aberta com dados vazados	Os dados são do dono desta linha?	Módulo 02
Senha roubada usada no login	O código chegou ao celular certo?	Módulo 03
Cliente perdido na estrada	Onde está o celular?	Módulo 04
Golpe da troca de chip	O chip deste número foi trocado?	Módulo 05

CAMARA: o mesmo contrato em toda operadora



Projeto aberto

Mantido na Linux Foundation, com a GSMA e as operadoras, desde 2022.

Especificação pública

Cada API tem um arquivo OpenAPI com campos, respostas e erros.

Troca sem reescrever

O mesmo código serve para qualquer operadora: muda a URL e o login.

Três camadas: quem faz o quê



CAMARA

a especificação

Define a pergunta, os campos, as respostas e os códigos de erro. Exemplo: verificationResult pode ser TRUE, FALSE, PARTIAL ou UNKNOWN.



GSMA Open Gateway

o programa e o sandbox

Reúne as operadoras, publica as APIs para as empresas e oferece o ambiente de testes que usamos nesta aula.



Operadoras

a implementação real

Respondem com dados de verdade em produção, com contrato, cobrança e consentimento do cliente.

O sandbox: como começamos a testar

1

Criar um app

Escolher as APIs liberadas: localização, KYC, OTP e outras.

2

Ativar escopos

Cada API tem um escopo, por exemplo kyc-match:match.

3

Gerar o token

Fluxo Client Credentials. O token vale só 5 minutos.

4

Chamar a API

POST com o token no cabeçalho Authorization: Bearer.

Não há operadora de verdade: as respostas são simuladas e os números de telefone são fictícios.

Ótimo para aprender a integração e preparar o sistema para todas as respostas possíveis.

O segredo do sandbox: os 2 últimos dígitos

+155500035

Final 35 na verificação de localização: resposta FALSE, fora da área.

00–24	25–49	50–74	75–89	90–93
TRUE	FALSE	PARTIAL	UNKNOWN	erros

Cada módulo tem a sua tabela. Algumas faixas não estão documentadas.

Nosso método: varredura

1. Chamar a API com os finais 00 a 99
2. Agrupar as respostas iguais
3. Comparar com a documentação
4. Testar se os dados enviados mudam algo

1.200+ chamadas ao sandbox nos 5 módulos

Anatomia de uma chamada

```
const resposta = await fetch(
  "https://open-gateway-sandbox.gsma.com" +
  "/device-location-verification/v1/verify", {
  method: "POST",
  headers: {
    Authorization: `Bearer ${TOKEN}`,
    "Content-Type": "application/json"
  },
  body: JSON.stringify({
    device: { phoneNumber: "+155500035" },
    area: { areaType: "CIRCLE",
      center: { latitude: 45.754, longitude: 4.86 },
      radius: 1000 },
    maxAge: 120
  })
});
```

RESPOSTA

```
200 OK
{
  "verificationResult": "FALSE",
  "lastLocationTime":
    "2023-09-07T10:40:52Z"
}
```

1. Endereço: servidor do sandbox + caminho da API
2. Token de 5 minutos no cabeçalho
3. Corpo em JSON: telefone e parâmetros

01

Verificação de localização

“Este celular está perto desta loja?”

API: Device Location Verification · pasta localizacao_seguranca

Sim ou não: o celular está nesta área?

PERGUNTA

O celular deste número está dentro desta área?

ENVIAMOS

Telefone, uma área (círculo: centro e raio) e a idade máxima da posição (maxAge)

RECEBEMOS

TRUE, FALSE, PARTIAL (com matchRate de 0 a 100) ou UNKNOWN

```
POST /device-location-verification/v1/verify
```

Onde se usa



Antifraude de cartão em compra presencial

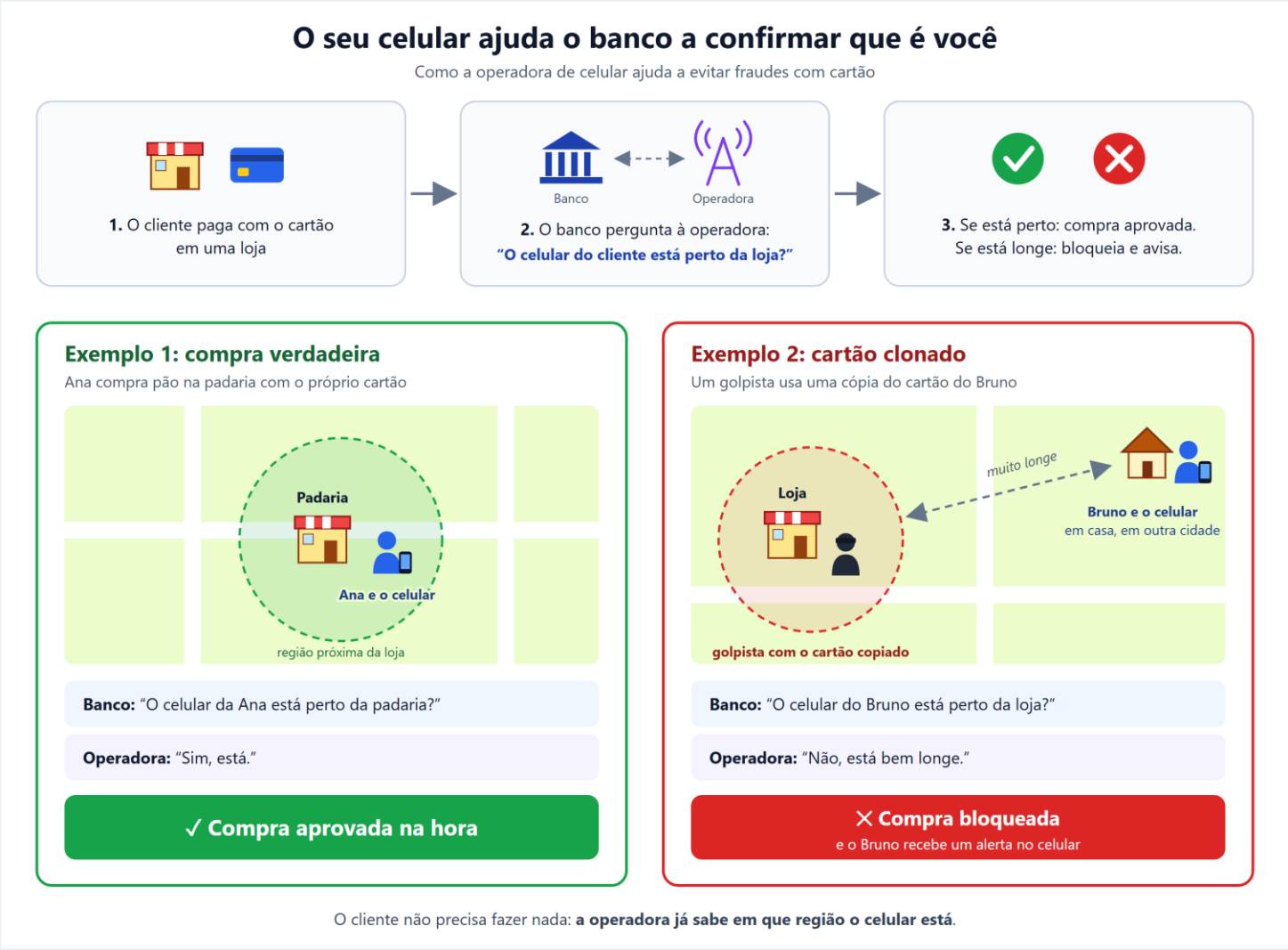


Confirmar Pix ou login no local de sempre



Check-in de técnico ou entregador

Cenário: antifraude de cartão



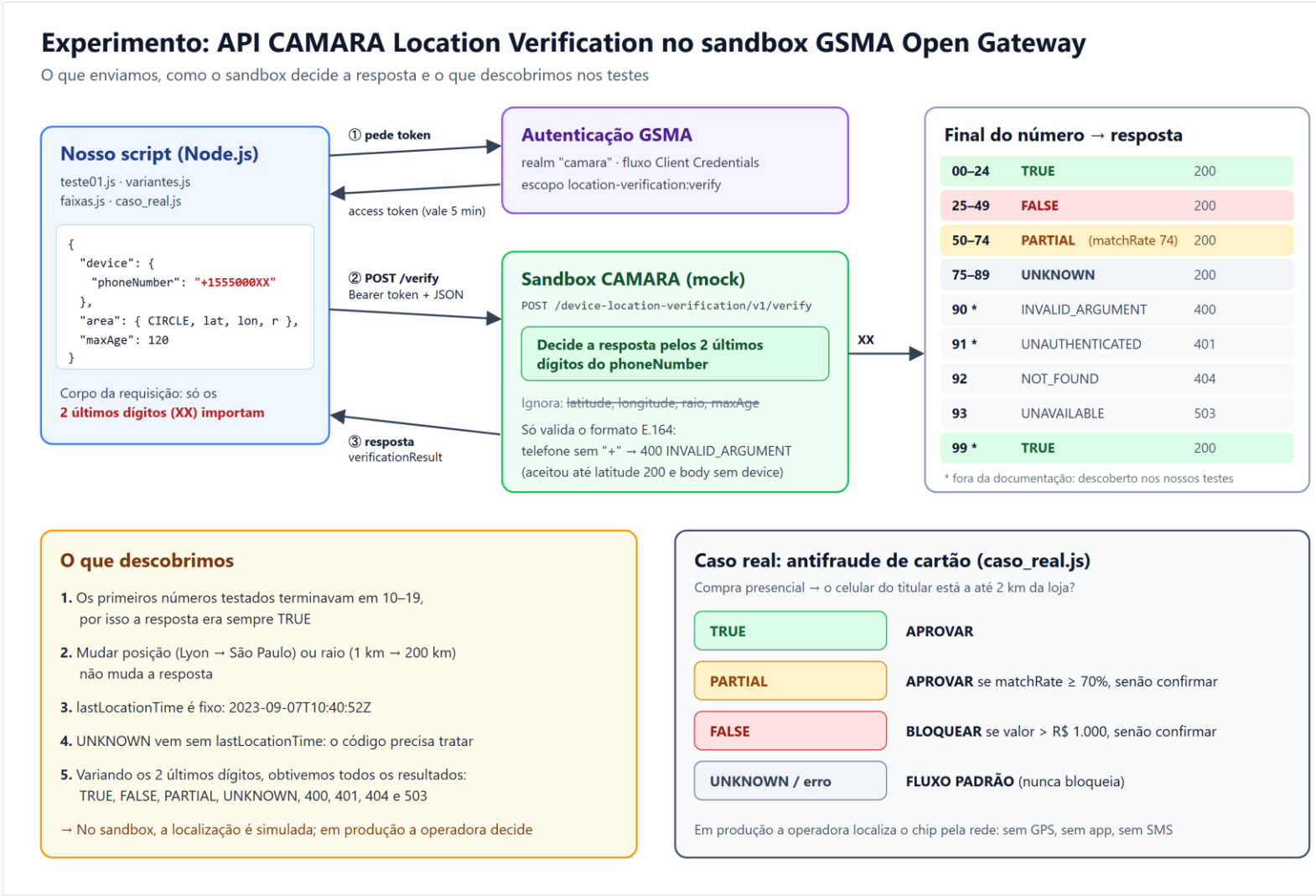
Para contar a história

1. Ana compra na padaria e o celular dela está perto: a compra é aprovada na hora.

2. O cartão do Bruno foi clonado: o celular dele está em outra cidade e a compra é bloqueada.

3. O cliente não faz nada: a operadora já sabe em que região o celular está.

As chamadas que fizemos



O que descobrimos

1. No início a resposta era sempre TRUE: os números testados terminavam em 10–19.
2. Posição e raio são ignorados no sandbox. Só o final do telefone decide.
3. Os finais 90, 91 e 99 respondem, mas não estão na documentação.

POC: autorizador de cartão (caso_real.js)

Regra de decisão TRUE aprova · PARTIAL com 70% ou mais aprova · FALSE acima de R$ 1.000 bloqueia, abaixo pede confirmação · UNKNOWN ou erro segue o fluxo padrão

Transação	Cliente	Valor	Loja	Operadora	Decisão
TX-001	Ana	R$ 89,90	Padaria Centro	TRUE	APROVAR
TX-002	Bruno	R$ 4.999,00	Eletrônicos Av. Paulista	FALSE	BLOQUEAR
TX-003	Carla	R$ 320,00	Farmácia Pinheiros	PARTIAL (74%)	APROVAR
TX-004	Diego	R$ 150,00	Posto Marginal	UNKNOWN	FLUXO PADRÃO
TX-005	Elisa	R$ 60,00	Mercado Mooca	503 indisponível	FLUXO PADRÃO

Vantagens e cuidados

Vantagens

Nenhum atrito para o cliente

Não precisa instalar app, ligar o GPS nem fazer nada: a rede já sabe a região.

Difícil de falsificar

A posição vem da antena, não do aparelho. O GPS do celular pode ser simulado por um app.

Privacidade

O banco recebe só sim ou não. A localização do cliente não sai da operadora.

Funciona em qualquer celular

Vale até para aparelhos simples, sem smartphone nem internet.

Desvantagens e cuidados

Precisão limitada

A área de uma antena vai de centenas de metros a quilômetros. Raio pequeno tende a dar PARTIAL ou UNKNOWN.

Posição pode estar velha

Use maxAge e confira o lastLocationTime da resposta.

Cliente sem o celular

Quem esqueceu o celular em casa gera um falso alerta: nunca bloquear só por isso.

Depende da operadora

Exige contrato, consentimento do cliente e tem custo por consulta.

02

Know Your Customer (KYC)

“Os dados que o cliente digitou são do dono desta linha?”

APIs: KYC Match, KYC Tenure e KYC Age Verification · pasta know_your_customer

A operadora confere o cadastro do cliente

MATCH

Nome, documento, endereço e e-mail batem com o dono da linha? Resposta campo a campo

TENURE

A linha está ativa desde uma data? É pré-paga, pós-paga ou empresarial?

AGE VERIFICATION

O titular tem a idade mínima? Informa também controle parental

```
POST /kyc-match/v0.2/match
POST /kyc-tenure/v0.1/check-tenure
POST /kyc-age-verification/v0.1/verify
```

Onde se usa

- Abrir conta sem foto de documento
- Apostas e vendas com idade mínima
- Detectar chip comprado para golpe

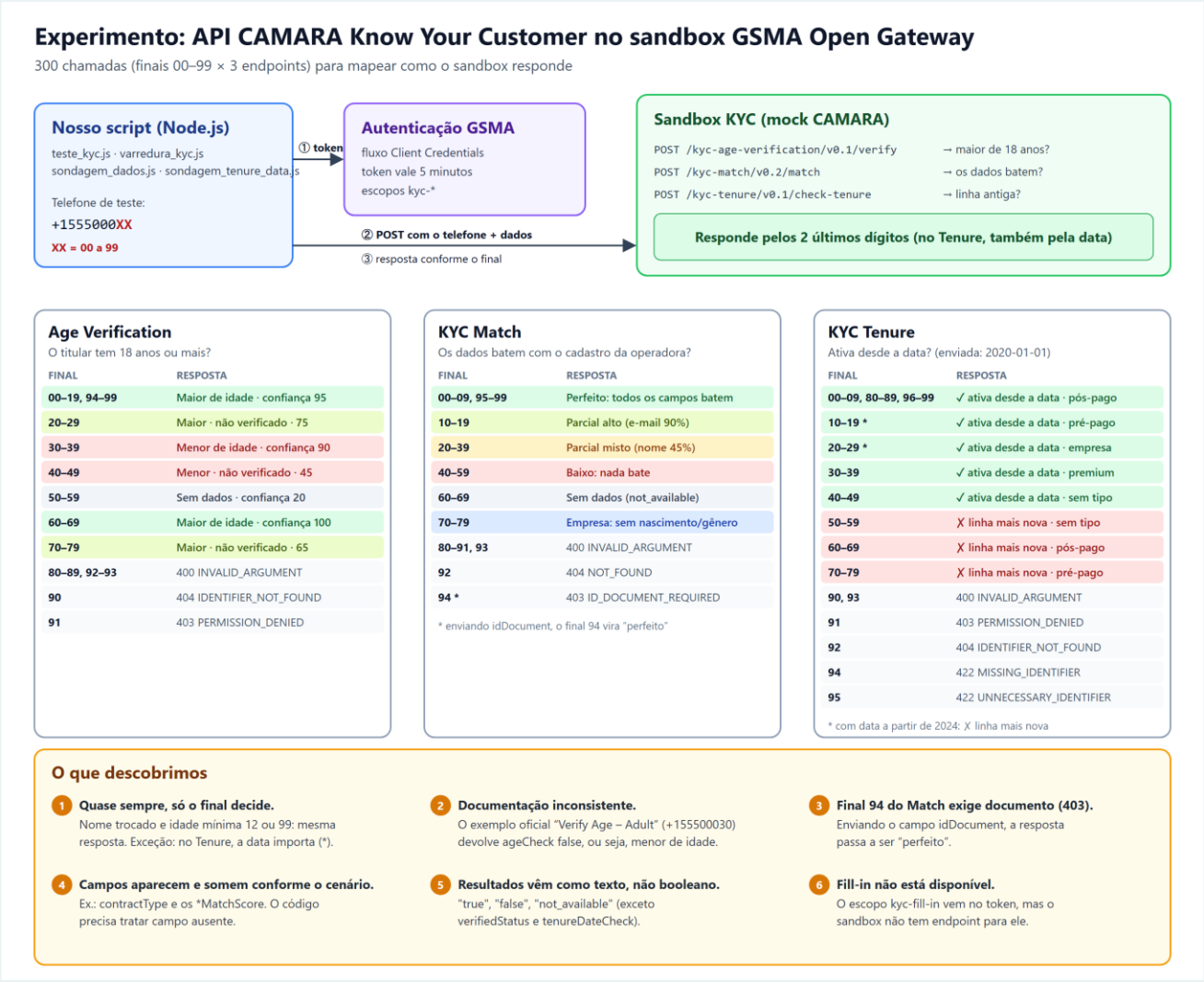
Cenário: abertura de conta digital



Para contar a história

1. Carla preenche o cadastro e a conta abre em 2 minutos, sem selfie e sem foto do RG.
2. Um golpista usa dados vazados da Paula com um chip novo: o cadastro é barrado.
3. A operadora responde só "confere" ou "não confere".

As chamadas que fizemos



O que descobrimos

1. 300 chamadas na varredura: 32 respostas diferentes mapeadas.

2. O exemplo oficial "Adult" devolve menor de idade: a documentação errou.

3. No Tenure a data enviada muda a resposta para os finais 15 e 25.

POC: abertura de conta (caso_real.js)

Regra de decisão Menor de idade recusa · Match baixo bloqueia · misto vai para análise · sem dados ou erro pede documento e selfie · linha com menos de 6 meses aprova com limite

Pedido	Cliente	Match	Linha	18+	Decisão
AC-001	Carla Lima	alto	antiga · pós	sim	APROVAR
AC-002	Rafael Souza	alto	nova · pré	sim	APROVAR COM LIMITE
AC-003	Marcos Pereira	misto	nova · pós	sim	ANÁLISE MANUAL
AC-004	Lucas Andrade	misto	antiga · premium	não	RECUSAR (menor)
AC-005	Paula Reis (golpe)	baixo	nova	sem dados	BLOQUEAR
AC-006	Diego Martins	sem dados	nova · pós	sim	MÉTODO TRADICIONAL
AC-007	Fábio Lima	alto	nova · pré	sim	APROVAR COM LIMITE
AC-008	Elisa Rocha	erro 404	erro 404	erro 400	MÉTODO TRADICIONAL

Vantagens e cuidados

Vantagens

Cadastro em minutos

Sem foto de documento e sem selfie: menos clientes desistem no meio.

Fonte confiável

A operadora já cadastrou o titular da linha com documento.

Privacidade

A operadora só diz “confere” ou “não confere”, sem entregar os dados.

Pega o chip descartável

O Tenure mostra linhas recém-criadas, comuns em golpes.

Desvantagens e cuidados

Cadastro desatualizado

Endereço antigo ou nome mudado na operadora geram “misto” para um cliente honesto.

Titular não é o usuário

Linhas no nome dos pais ou de uma empresa respondem pelo titular, não por quem usa.

Nem todo cadastro foi verificado

O campo verifiedStatus mostra quando o dado é só declarado.

Não resolve tudo sozinho

Regras do setor podem exigir outras verificações. Cobertura e preço variam por operadora.

03

Código por SMS (OTP)

“O código que o cliente digitou é o que a operadora mandou?”

API: One Time Password SMS · pasta otp_sms

A operadora envia e confere o código

1. ENVIAR

Telefone + texto com {{code}}. Recebemos um authenticationId, o “protocolo”

2. VALIDAR

Protocolo + código digitado. Recebemos 204 (aceito) ou um erro

DETALHE

O app nunca vê o código: só a operadora e o celular do cliente

```
POST /one-time-password-sms/v1/send-code
POST /one-time-password-sms/v1/validate-code
```

Onde se usa



Login no app

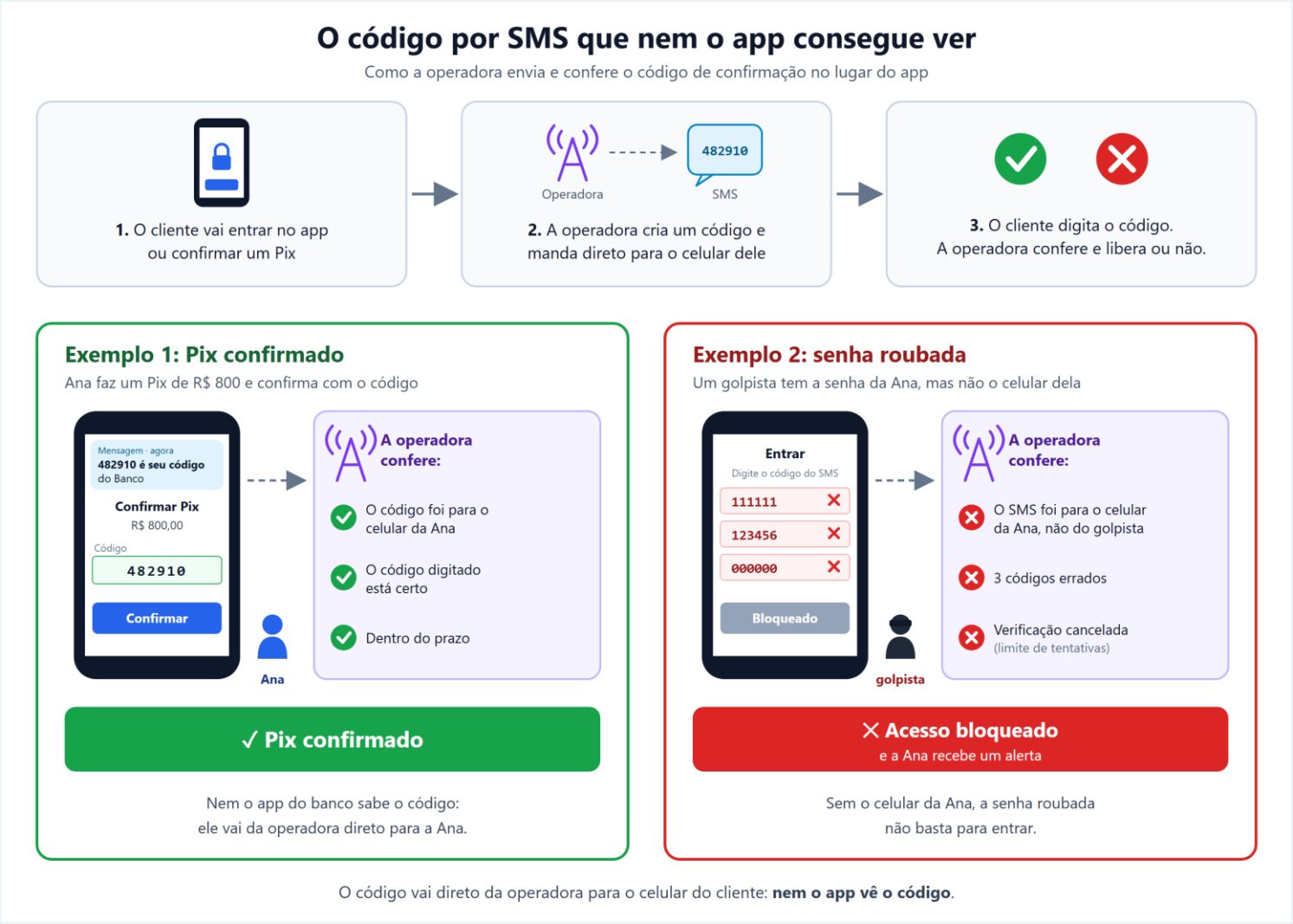


Confirmar Pix ou troca de senha



Confirmar o número no cadastro

Cenário: login e Pix com código



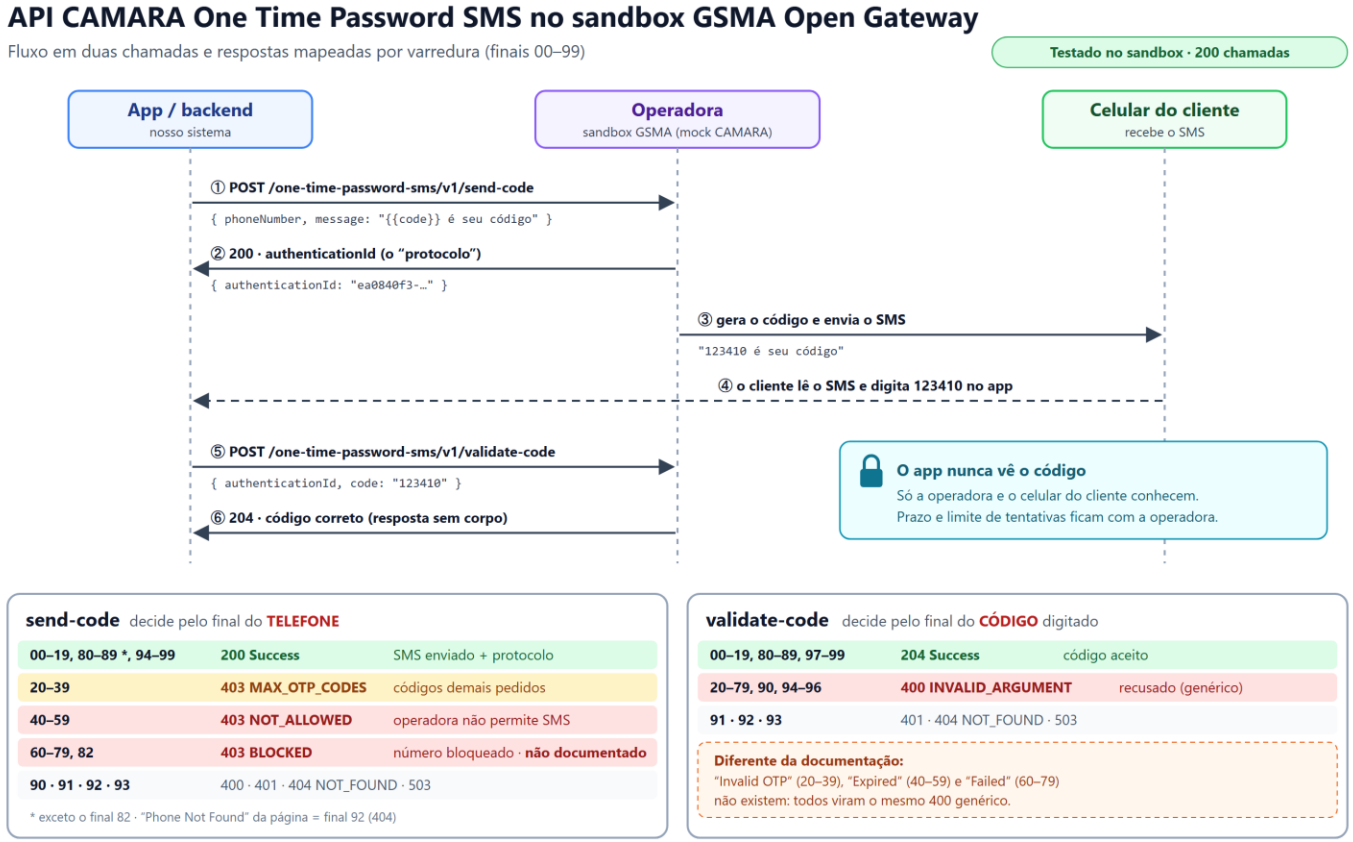
Para contar a história

1. Ana confirma um Pix de R$ 800 com o código que chegou ao celular dela.

2. Um golpista tem a senha da Ana, mas não o celular: erra os códigos e é bloqueado.

3. Atenção: na troca de chip o SMS vai para o golpista. Combinar com a API SIM Swap.

As chamadas que fizemos



O que descobrimos

1. Os finais 60–79 e 82 devolvem PHONE_NUMBER_BLOCKED, que não está na documentação.

2. Código errado, expirado e tentativas demais viram o mesmo 400 genérico.

3. O authenticationId do sandbox é sempre o mesmo valor.

POC: login e Pix com código (caso_real.js)

Regra de decisão SMS recusado: aguardar ou usar outro método · código recusado conta uma tentativa · 3 erros bloqueiam e avisam o cliente

Operação	Cliente	Situação	O que aconteceu	Decisão
OP-001	Ana	Pix de R$ 800	código aceito	LIBERAR
OP-002	Golpista	Login com senha roubada	3 códigos recusados	BLOQUEAR E ALERTAR
OP-003	Bruno	Login	erra e depois acerta	LIBERAR
OP-004	Carla	Troca de senha	número bloqueado para SMS	OUTRO MÉTODO
OP-005	Diego	Pix de R$ 150	códigos demais pedidos	AGUARDAR
OP-006	Elisa	Login	SMS não permitido	OUTRO MÉTODO

SMS tradicional × código pela operadora

	SMS tradicional (agregador)	Código pela operadora (CAMARA)
Quem gera o código	O nosso app	A operadora
Onde o código fica	No banco de dados e nos logs do app	Só na operadora e no celular do cliente
Prazo e tentativas	O app precisa programar	A operadora controla
Caminho da mensagem	App → agregador → operadora → celular	Operadora → celular
Integração	Uma chamada: enviar o texto pronto	Duas chamadas: enviar e validar
Cobertura	Qualquer número, em qualquer operadora	Só operadoras que oferecem a API
Troca de chip	Vulnerável	Vulnerável: combinar com o SIM Swap

Nos dois casos o código chega por SMS. A diferença é quem gera, guarda e confere o código.

Vantagens e cuidados

Vantagens

O código não passa pelo app

Não há código guardado em banco de dados ou em log para vazar.

Regras de segurança prontas

Prazo de validade, limite de tentativas e de envios ficam com a operadora.

Menos intermediários

A mensagem sai direto da operadora, sem passar por um agregador de SMS.

Padrão único

A mesma integração vale para qualquer operadora que ofereça a API.

Desvantagens e cuidados

Continua sendo SMS

Na troca de chip o código chega ao golpista. Combinar com o SIM Swap (módulo 05).

Engenharia social

Se o cliente for enganado e repassar o código, nenhuma API impede.

Cobertura menor

Só funciona com operadoras que oferecem a API. O agregador alcança qualquer número.

Erros pouco detalhados no sandbox

Código errado, expirado e tentativas demais vieram como o mesmo 400.

04

Localização do aparelho

“Onde está este celular agora?”

API: Device Location Retrieval · pasta device_location_retrieval_01

A operadora devolve onde o celular está

PERGUNTA

Onde está o celular deste número?

ENVIAMOS

Só o telefone e, se quiser, a idade máxima da posição (maxAge)

RECEBEMOS

Uma área aproximada: círculo (centro e raio) ou polígono, com o horário da posição

```
POST /device-location-retrieval/v0.3/retrieve
```

Onde se usa



Assistência 24h e guincho

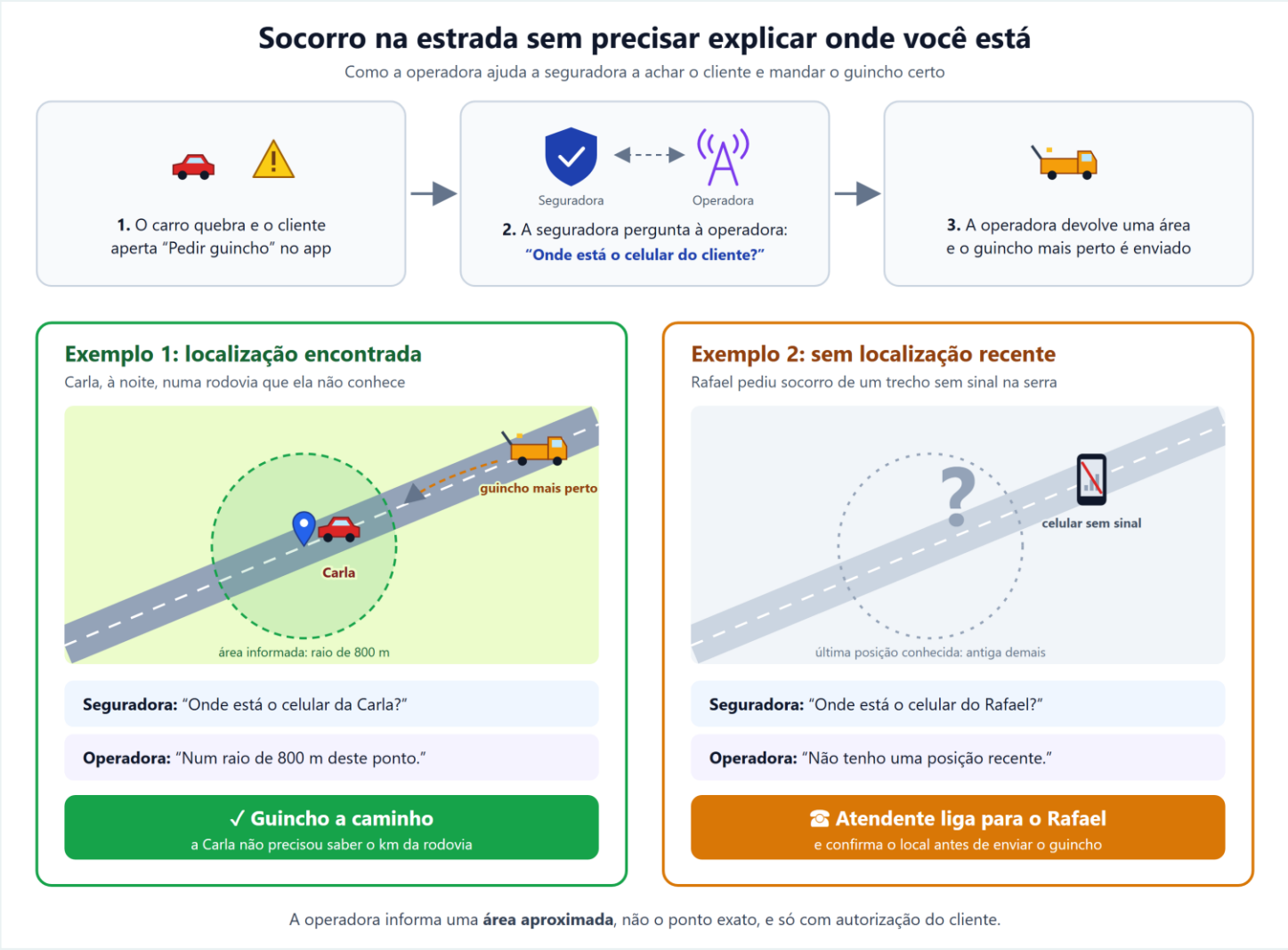


Atendimento de emergência



Gestão de frota e entregas

Cenário: socorro na estrada



Para contar a história

1. Carla, à noite numa rodovia: a operadora informa um raio de 800 m e o guincho vai até ela.

2. Rafael está sem sinal: sem posição recente, o atendente liga para confirmar o local.

3. A área é aproximada e só é consultada com autorização do cliente.

As chamadas que fizemos

API CAMARA Device Location Retrieval no sandbox GSMA Open Gateway

"Onde está este celular?" A resposta é uma área: círculo ou polígono

Testado no sandbox · 200 chamadas

Nosso script (Node.js)

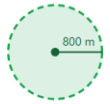
teste_localizacao.js · caso_real.js
varredura_localizacao.js

```
POST /device-location-retrieval
/v0.3/retrieve
{ "device": {
"phoneNumber": "+1555000XX" },
"maxAge": 120 }
maxAge: idade máx. da posição (s)
```

Sandbox: devolve uma área conforme o final do telefone

CIRCLE · finais 00–49 e 94–99

```
"lastLocationTime": "<agora>",
"area": { "areaType": "CIRCLE",
"center": { "latitude": 45.754,
"longitude": 4.86 },
"radius": 800 }
```



POLYGON · finais 50–89

```
"lastLocationTime": "<agora>",
"area": { "areaType": "POLYGON",
"boundary": [
{45.754, 4.86}, {45.7541, 4.8601},
{45.7542, 4.8602}, {45.754, 4.86} ] }
```



Final do telefone → resposta

igual com e sem maxAge

00–49, 94–99	**200 · CIRCLE**	círculo de 800 m
50–89	**200 · POLYGON**	polígono de 3 pontos
90	400 INVALID_ARGUMENT	
91	401 UNAUTHENTICATED	
92	404 LOCATION_RETRIEVAL.DEVICE_NOT_FOUND	
93	503 UNAVAILABLE	

Cenários da página × o que encontramos

Circle	✓ finais 00–49, 94–99
Polygon	✓ finais 50–89
No Maxage (Success)	✓ sem maxAge: mesmas respostas
Error Invalid Phone	✓ final 90 (400)
Error Device Not Found	✓ final 92 (404)
Error Service Unavailable	✓ final 93 (503)
Error Permission Denied	⚠ não aparece: 91 dá 401

O que descobrimos

1. **A posição é sempre "agora".**
   lastLocationTime vem com o horário da consulta: não dá para simular "posição antiga" no sandbox.
2. **O lugar é sempre o mesmo.**
   Centro em Lyon (45.754, 4.86) para qualquer número.
3. **maxAge não muda nada.**
   Com 120, 1, 0 ou sem o campo: mesma resposta.
4. **O polígono é minúsculo (~17 m).**
   3 pontos, e o 1º se repete no fim para fechar a figura. O código precisa saber tratar círculo e polígono.
5. **"Permission Denied" não foi reproduzido.**
   A página lista o cenário, mas nenhum final devolve 403.
6. **Uma falha passageira.**
   O final 44 deu 400 uma vez; repetido, deu 200.

Em produção a área depende da rede (antenas): em cidade, centenas de metros; em estrada, pode passar de quilômetros.

O que descobrimos

1. Finais 00–49 devolvem círculo, 50–89 polígono e 90–93 erros.
2. A posição é sempre "agora" e sempre em Lyon. O maxAge não muda nada.
3. O erro 403 aparece quando o token não tem a permissão da API.

POC: assistência 24h (caso_real.js)

Regra de decisão Área de até 2 km: envia o guincho mais próximo · área maior: envia e liga para confirmar · posição com mais de 10 min ou erro: liga para o cliente

Chamado	Cliente	Resposta da operadora	Decisão
SOS-01	Carla	círculo de 800 m	**ENVIAR GUINCHO · 2,2 km, cerca de 13 min**
SOS-02	Marcos	polígono (cerca de 17 m)	**ENVIAR GUINCHO · polígono convertido em centro + raio**
SOS-03	Rafael	404: aparelho não localizado	**LIGAR PARA O CLIENTE**
SOS-04	Diego	503: serviço indisponível	**LIGAR PARA O CLIENTE**
SOS-05	Lucas	401: credencial recusada	**LIGAR E AVISAR A EQUIPE TÉCNICA**
SOS-06	Elisa	400: requisição inválida	**LIGAR PARA O CLIENTE**

Vantagens e cuidados

Vantagens

Localiza sem app e sem GPS

Funciona mesmo que o cliente não saiba ou não consiga dizer onde está.

Atendimento mais rápido

O guincho ou o socorro sai sem depender de uma ligação para explicar o local.

Qualquer celular

Vale para aparelhos simples, sem internet.

Resposta pronta para usar

Círculo ou polígono, já com o horário da posição.

Desvantagens e cuidados

Área aproximada

Em estrada, a área pode passar de quilômetros. Não é o ponto exato.

Dado sensível

Exige consentimento explícito e uso restrito à finalidade (LGPD).

Sem sinal, sem posição

Celular desligado ou fora de cobertura não é localizado.

Só a posição recente

Não há histórico de onde o celular esteve.

05

Troca de chip (SIM Swap)

“O chip deste número foi trocado recentemente?”

API: SIM Swap · pasta sim_swap

A operadora conta quando o chip foi trocado

CHECK

Foi trocado nas últimas X horas (maxAge de 1 a 2400)? Resposta: swapped true ou false

RETRIEVE-DATE

Quando foi a última troca? Resposta: uma data, ou null se nunca foi trocado

POR QUE IMPORTA

No golpe da troca de chip, o SMS do banco passa a chegar ao golpista

```
POST /sim-swap/v1/check
POST /sim-swap/v1/retrieve-date
```

Onde se usa



Antes de Pix alto ou troca de senha



Decidir se é seguro enviar código SMS



Cadastrar um novo celular no app

Cenário: o golpe da troca de chip



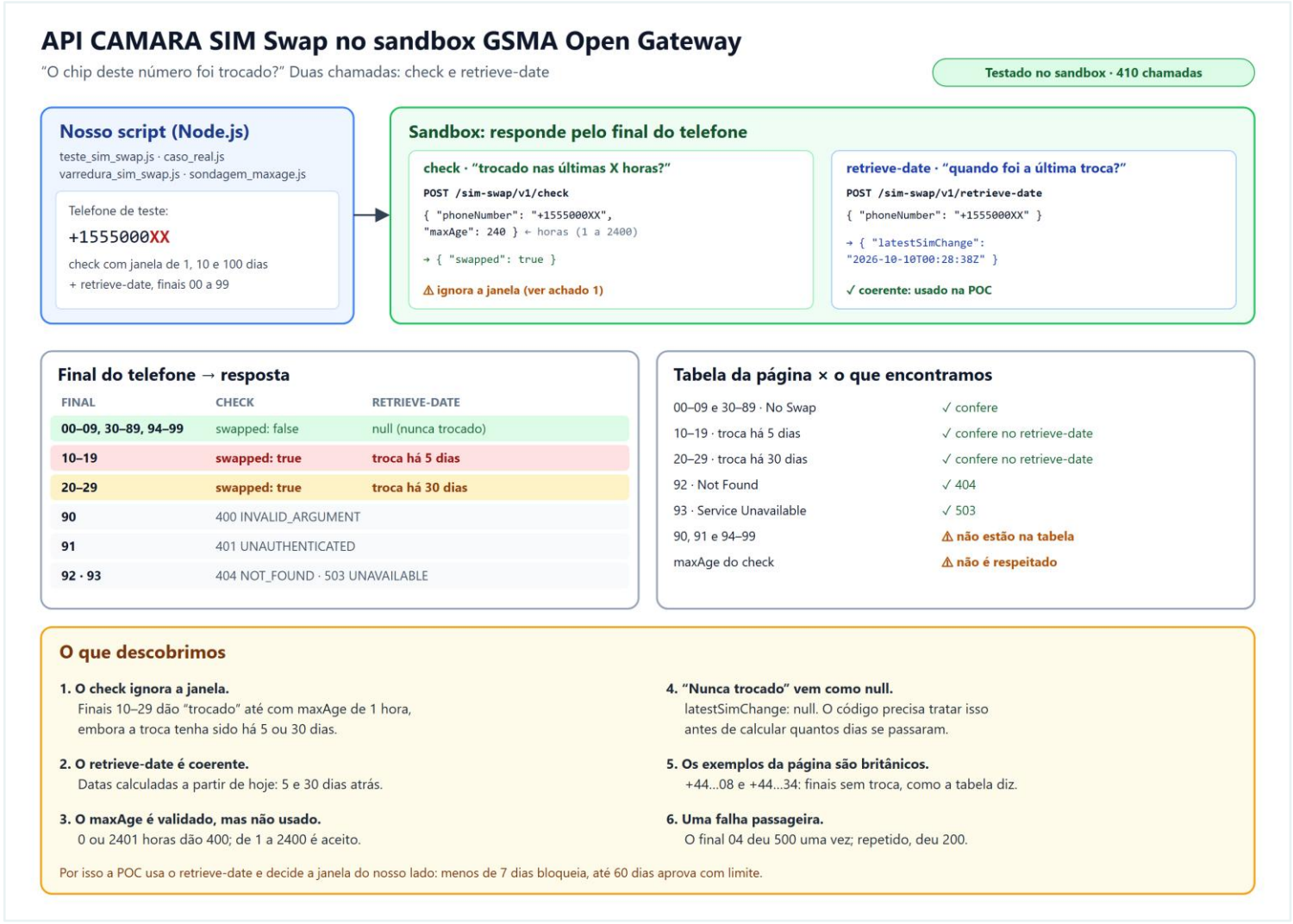
Para contar a história

1. Ana tem o chip de sempre: o código SMS é enviado e o Pix segue.

2. O golpista ativou o número do Bruno num chip novo: o banco não envia o SMS.

3. Troca recente pede verificação extra, não bloqueio: quase toda troca é legítima.

As chamadas que fizemos



O que descobrimos

1. Finais 10–19: troca há 5 dias. Finais 20–29: há 30 dias. Os demais nunca trocaram.

2. O check ignora a janela: responde "trocado" até com maxAge de 1 hora.

3. Por isso a POC usa o retrieve-date e calcula a janela do nosso lado.

POC: proteção de operações (caso_real.js)

Regra de decisão Troca há menos de 7 dias bloqueia e pede biometria · até 60 dias libera com limite · nunca trocado libera · operadora sem resposta pede verificação extra

Operação	Cliente	Ação	Última troca	Decisão
OP-01	Ana	Pix de R$ 5.000	nunca	LIBERAR
OP-02	Bruno	Troca de senha por SMS	há 5 dias	BLOQUEAR E VERIFICAR
OP-03	Carla	Pix de R$ 2.000	há 30 dias	LIBERAR COM LIMITE
OP-04	Diego	Novo celular no app	nunca	LIBERAR
OP-05	Elisa	Pix de R$ 800	erro 404	VERIFICAÇÃO EXTRA
OP-06	Fábio	Troca de senha por SMS	erro 503	VERIFICAÇÃO EXTRA

Vantagens e cuidados

Vantagens

- **Pega o golpe antes do prejuízo**
  A troca recente aparece antes de o golpista usar o SMS.
- **Invisível para o cliente**
  Nenhuma etapa a mais para quem não trocou de chip.
- **Simples de integrar**
  Uma chamada, uma data na resposta.
- **Completa o código SMS**
  Diz quando ainda dá para confiar no SMS do módulo 03.

Desvantagens e cuidados

- **Troca legítima é comum**
  Celular novo ou chip perdido geram alerta: pedir verificação, não bloquear de vez.
- **Não pega todo golpe**
  Celular roubado com o chip dentro ou engenharia social passam sem troca.
- **check × retrieve-date**
  No sandbox o check ignorou a janela. Conferir a data e decidir no nosso código.
- **Portabilidade**
  Confirmar com cada operadora se mudança de operadora conta como troca.

Os 5 módulos lado a lado

Módulo	Pergunta	Resposta	Achado no sandbox
01 · Verificação de localização	O celular está nesta área?	TRUE, FALSE, PARTIAL ou UNKNOWN	Posição e raio ignorados; finais sem documentação
02 · Know Your Customer	Os dados são do dono da linha?	Campo a campo: true, false ou not_available	Exemplo “Adult” devolve menor; no Tenure a data importa
03 · Código por SMS	O código digitado está certo?	204 aceito ou erro	Validação só distingue aceito de recusado
04 · Localização do aparelho	Onde está o celular?	Círculo ou polígono	Posição sempre “agora” e sempre em Lyon
05 · Troca de chip	O chip foi trocado?	swapped ou data da troca	O check ignora a janela; o retrieve-date é coerente

O que levamos para a prática



Sandbox é para integrar

Ele ensina o formato das chamadas e das respostas. Não mede se a operadora acerta.



Teste tudo

A documentação errou em todos os módulos: exemplos trocados, erros que não existem e erros sem documentação.



Combine APIs

Código SMS com SIM Swap; KYC com localização. Uma API sozinha raramente decide.

Próximos passos

- **Piloto com uma operadora real**
- **Consentimento do cliente e LGPD**
- **Juntar OTP e SIM Swap no fluxo**

Perguntas?

Scripts, imagens e resultados estão nas 5 pastas do projeto: localizacao_seguranca · know_your_customer · otp_sms · device_location_retrieval_01 · sim_swap